

Per-entity anomaly detection in security telemetry

John Pierman · github.com/JohnPierman/ethogram

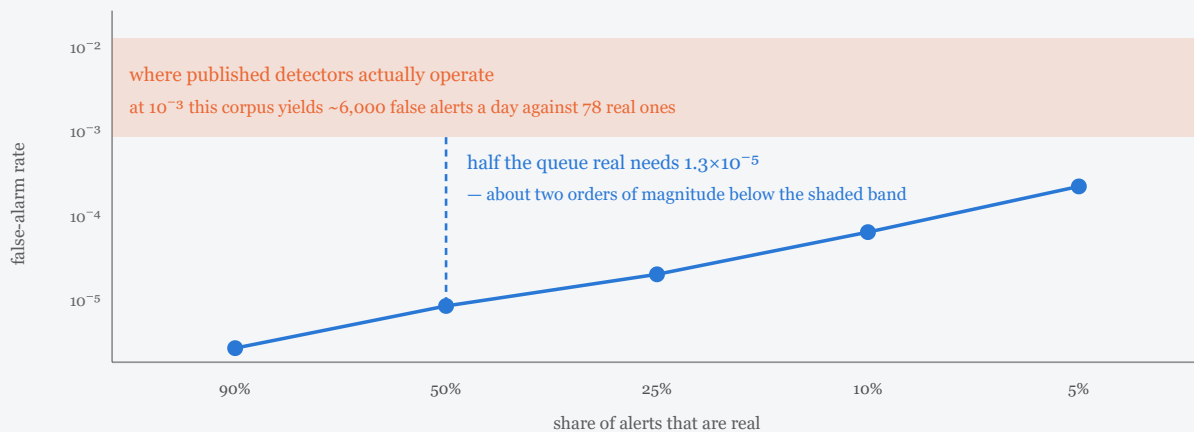
Every number in this paper is read from a recorded run committed under `results/`. Where a claim has no backing run, the section says so and is left empty rather than filled.

1. The problem

An intrusion detector reads authentication logs and decides which events an analyst should look at. The difficulty is arithmetic before it is anything else.

On the public LANL corpus used throughout this paper, days 7 to 13 contain **42,218,530 scored events, of which 549 are labelled red-team activity** — a base rate of 1.30×10^{-5} , or one in 76,901.

false-alarm rate needed for a given share of alerts to be real, at this corpus's base rate



The base rate, not the model, sets the ceiling. Over the scored window this corpus carries 549 labelled events among 42,218,530 — one in 76,901. Inverting the arithmetic for a desired precision gives the false-alarm rate a detector would have to achieve, and it lands two to three orders of magnitude below where published detectors operate. Two consequences follow: "everything suspicious and nothing else" is not attainable here by any known method, and even a perfect detector still yields 87 alerts a day, because 78 genuinely suspicious events happen daily. What an operator can choose is the error rate; the volume follows from it.

At that base rate, precision is governed by the false-alarm rate and almost nothing else. For a detector that misses nothing, the share of alerts that are real is

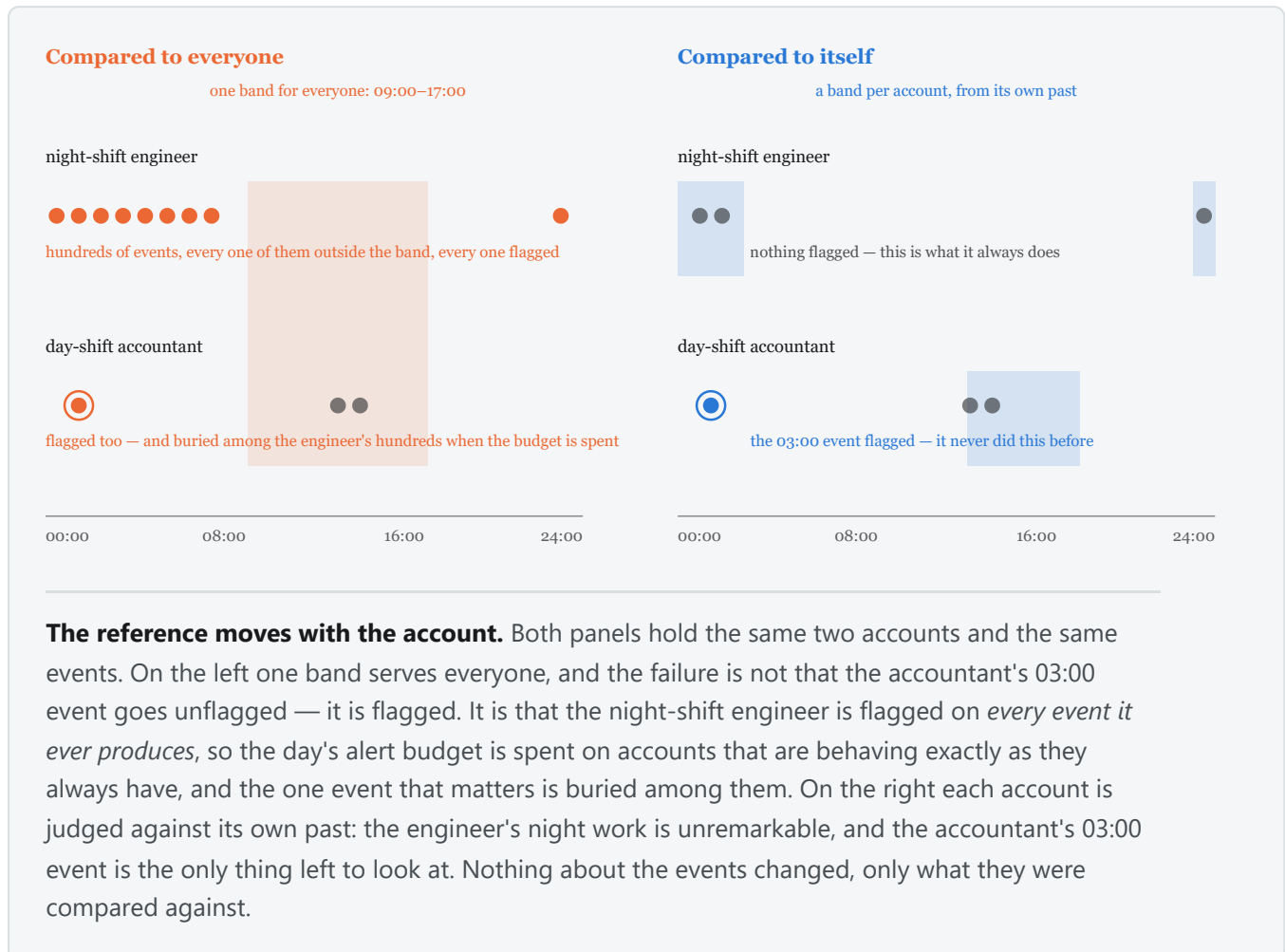
$$P(\text{intrusion} \mid \text{alarm}) = p / (p + (1 - p) \cdot \alpha)$$

so a queue that is half real requires $\alpha \approx 1.3 \times 10^{-5}$: about 78 false alerts a day against 78 real ones. Axelsson reached the same order of magnitude in 1999 from a structurally identical scenario, and concluded that suppressing false alarms, rather than recognising intrusions, is the binding constraint. Published detectors typically operate two to three orders of magnitude above what the arithmetic permits.

1.1 Why the standard formulation cannot get there

The conventional approach reduces each event to a fixed-length numeric vector and fits one model over the pooled cloud: isolation forests, local outlier factor, one-class SVM, PCA reconstruction error, autoencoders. All are instances of the same question — **is this point unusual for the population?**

That question is the wrong one, and the failure is not a matter of tuning.



A night-shift engineer authenticating at 03:00 is unusual for the organisation and entirely ordinary for herself. A population-scope model flags her every night. Worse, it flags her *hundreds of times*, so when a budget is spent she consumes it, and the one account that has genuinely changed behaviour is buried. The corpus bears this out: of the 549 labelled events, **not one is a population-marginal outlier**.

The question worth asking is *is this unusual for **this** account, against its own history*. An account that habitually departs from the population norm is not thereby anomalous. That single commitment is what this work is about, and it is also the axis its results divide along.

1.2 What a usable answer looks like

Three properties follow from the arithmetic, and they are requirements rather than aspirations.

A score must be **comparable**: not "0.87 anomalous" but a p-value under an explicitly stated null, so that two detectors' outputs can be reasoned about together and a threshold means something.

A detector with no inputs must **decline**. Silence and normality are different findings, and a system that reports the second when it means the first is quietly wrong at scale.

A verdict must carry **evidence**: if an analyst cannot reconstruct why an event surfaced, the alert generates work rather than reducing it.

2. The approach and the framework

2.1 The entity-conditioned null

Every detector states a null hypothesis of the same shape:

H₀ — the observed value is drawn from *this entity's own* historical distribution, estimated from its decayed counts.

The framework holds seven such detectors. Each returns a p-value under its stated null, or abstains. Five ask about the entity; two ask about the population, and are kept deliberately so that the per-entity arms can be credited only with what they add beyond what a conventional model already does.

DETECTOR	NULL HYPOTHESIS	SCOPE	DEFAULT
I <code>novelty</code>	the value is drawn from the entity's historical distribution over that field	entity	on
II(a) <code>timing</code>	the event's time of day is drawn from the entity's historical circular density	entity	on
II(b) <code>volume</code>	the count in this window is drawn from the entity's negative binomial	entity	on
III <code>cooccurrence</code>	the pair's co-occurrence weight is drawn from a Poisson degree-corrected block model	population	on
IV <code>marginal</code>	the value is drawn from the population marginal for its field	population	on
V <code>noveltyrate</code>	the count of first-ever values in this window follows the entity's own historical rate	entity	opt-in
— <code>pairing</code>	the pairing is drawn from the entity's own history of pairings	entity	opt-in

2.2 No component knows what a field is

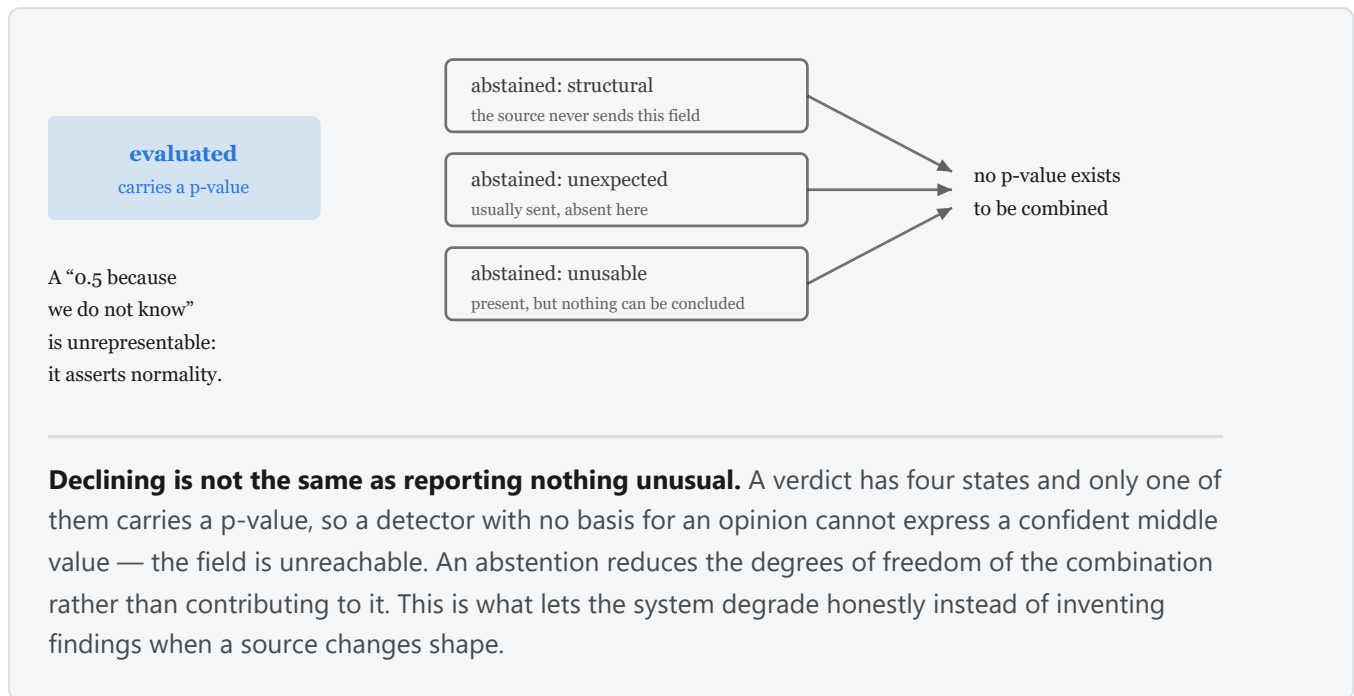
The framework names no field anywhere in its code. Readers emit every value as text; a registry infers each field's *kind* from the values it observes — categorical, boolean, discrete, continuous, identifier — together with the statistics supporting that classification. Detectors iterate the registry; none names a field.

Nothing is cast to a type. A per-batch cast would make a value's reading depend on which rows it arrived with, would merge values a source distinguishes (`007` and `7`, `TRUE` and `true`), and would commit before the evidence is in, since a column that looks integral for forty-nine events can emit a sentinel on the fiftieth. Instead each kind supplies the *representation* its detectors can score: the value's own text where the vocabulary is already bounded, and a fixed-boundary magnitude band where it is not.

The identifier case is load-bearing. A field taking a distinct value on essentially every event is formally maximally novel on every observation; untreated it saturates any novelty detector, grows state without bound, and reduces a co-occurrence graph to singletons. Such fields are detected from their statistics and contribute neither state nor verdicts.

Measured: a second, structurally unrelated source — LANL DNS — was admitted and scored with **zero changes to any extractor**, reading 6,004,253 rows and scoring 5,599,989 events.

2.3 Abstention is a first-class outcome



A verdict carries a four-valued status. **evaluated** carries a p-value; the three abstentions say *why* there is none — the input was absent and the source does not ordinarily produce it, the input was absent and it ordinarily does, or the input was present but not interpretable. A p-value is unreachable unless the status is **evaluated**, so an abstention cannot be silently read as normality.

2.4 Determinism, and evidence

Identical event and state must produce identical output. This requires closing specific leaks — no wall clock and no randomness in the scoring path, and a canonical total ordering before every floating-point reduction — and it is enforced structurally, by an AST-level test rather than by convention.

Measured: one probe event scored inside batches of **37, 38, 87, 537 and 2,037** events yielded the identical combined p-value of $1.2637402747461349 \times 10^{-5}$ in every case. The same event scored 64 times against the same state produced **one digest**. A deliberately defective detector, standardising against its own batch, is required to *fail* the same check, and does — because a check that cannot fail is not evidence.

Measured: **79.2% of 49,581 sampled verdicts** were reconstructable by hand from the evidence card alone, with no query back to the store.

2.5 The requirements

REQUIREMENT	ENFORCED BY
R1 No score may depend on the composition of the batch the event arrived in	Score reads only persisted state; E8 asserts byte-identical scores across batch sizes, with a negative control proving the check can fail
R2 No component may require advance knowledge of a field's type, cardinality or value set	readers emit generic field paths; the registry infers kinds; the estimator reserves mass for the unseen
R3 A detector without inputs must decline rather than assert normality	a p-value is unreachable unless the status is evaluated
R4 Identical event and state must yield identical output, reproducibly	no wall clock and no randomness in the scoring path, enforced by an AST-level test
R5 Every verdict must carry evidence sufficient to reconstruct it by hand	sufficient statistics <i>are</i> the evidence; E7 measures the share that reconstruct
R6 An alerted entity must be more likely than not to be genuinely anomalous. Alert volume is explicitly not bounded	nothing yet — measured, not asserted, and currently unmet

R6 replaced an earlier requirement that an operator-chosen error rate map to a predictable alert volume. That requirement was withdrawn rather than satisfied: it was never met, its enforcement mechanism was measured to be vacuous on this corpus, and holding it made a bounded queue the objective when the binding problem is that the queue's contents are wrong. R6 is the only requirement here that is not a structural property, and that is stated rather than glossed: R1–R5 fail a build, R6 can only be measured against labelled data.

2.6 What an alert is worth

Alert volume is deliberately unbounded. The objective is

$$U = v \cdot TP - c \cdot FP$$

where v is what catching one incident is worth and c what one wasted investigation costs. Only the ratio is identifiable from counts, so the operator supplies one number. A queue is worth reading exactly when $TP/FP > c/v$, so a target true-to-false ratio is the exchange rate — but utility also says *how many* rows to take, which a ratio cannot.

This matters because maximising TP/FP directly does not work. It is precision under a monotone transform, $P/(1-P)$, so its maximiser is the smallest queue containing a true positive; forbidding $TP = 0$ moves that corner from "alert on nothing" to "alert on one thing" rather than removing it. An objective must contain a term that grows with true positives found.

A budget is therefore a **ceiling, not a quota**: within it, the queue is truncated where marginal alerts stop paying.

3. Results

All figures are at matched alert budgets, expressed per analyst-day.

3.1 The per-entity detectors detect; the composite does not

Labelled LANL red-team events caught, days 7–14:

ARM	SCOPE	10/DAY	25/DAY	50/DAY	100/DAY
I novelty	entity	11	26	38	60
pairing	entity	4	8	8	59
IV marginal	population	0	0	0	0
II(a) timing	entity	0	0	0	0
II(b) volume	entity	0	0	0	0
composite (Fisher + Brown)	mixed	0	0	0	0

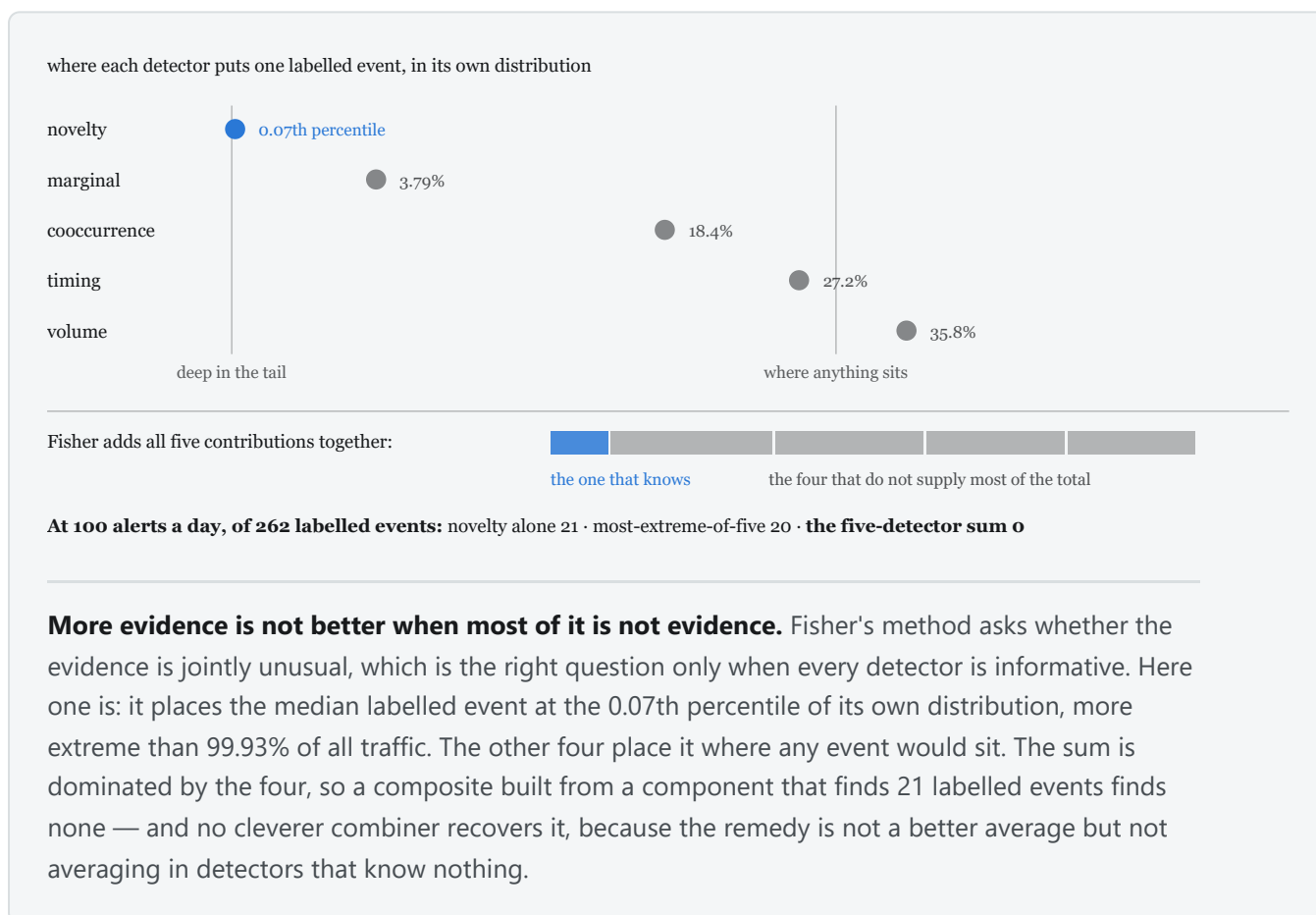
lanl-r11-d7-14-001 , 549 labelled events among 4,190,603 scored.

Replicated on a disjoint entity sample (lanl-holdout-r7-fixed-d7-9-001 , 262 labelled among 1,427,225 scored): novelty catches 2, 8, 15 and 21; cooccurrence catches 1, 2, 2, 2; the composite catches 0 at every budget.

At the tightest budget the novelty detector returns **11 true positives in 70 alerts — 16% precision against a base rate of 1.31×10^{-4} , a lift of about 1,200 $\times$** . Precision *improves* as the budget tightens, which is the signature of a ranking that is working.

The composite catches nothing at any budget on either corpus while its own best component catches 60. This is the paper's central negative finding and it is not a calibration detail.

3.2 The combination layer destroys the signal



Two combination rules are implemented. At 100 alerts/day:

CONFIGURATION	LANL-R11 (549)	LANL-HOLDOUT-R7-FIXED (262)
novelty alone	60	21
corrected minimum, Šidák	47	20
Fisher + Brown (<i>the reported composite</i>)	0	0

No combination rule beats the best single detector. Combining *subtracts* value.

Both failures are diagnosed, and the diagnoses differ:

Fisher averages an informative detector with uninformative ones. Labelled events sit at the 0.07th percentile of the novelty detector's own distribution and at the 18th to 36th of every other detector's. Summing $-2 \ln P$ across five detectors dilutes one signal with four non-signals. Fisher is powerful against diffuse alternatives; this signal is sparse.

The minimum compares raw p-values across detectors that share no scale. Under it the novelty detector carries 1,273 of the 1,400 retained alerts, so the population marginal's signal never becomes the minimum however extreme it is *within its own distribution*. That signal is not weak; it is unreachable.

The second diagnosis predicts its own fix. Conformal calibration replaces each detector's model tail with its rank in that detector's own burn-in distribution, which is exactly what puts several detectors on one scale. At entity scope it already moves recall from 15 of 46 to 25 of 46.

A related incompatibility was found while measuring the sixth detector: with six detectors the burn-in covariance implies $\text{Var}[X^2] = -27.5$, which no joint distribution of the statistics can produce. The estimator is measuring the marginals' misspecification rather than the detectors' dependence.

3.3 Detection by attack type

Against 856 synthetic attacks planted with controlled ground truth across six types, at 700 alerts over seven days and 1,405 labelled events:

ARM	ACCT TAKEOVER	CRED SPRAY	LATERAL	LOW & SLOW	OFF HOURS	PRIV ESC	REAL CAMPAIGN
IV marginal	76/120	0/320	0/40	0/288	0/64	0/24	0/549
I novelty	0	0	0	0	0	0	60/549
pairing	0	0	0	0	0	0	59/549
II(a) timing	0	0	0	0	0	0	1/549
II(b) volume	0	0	0	0	0	0	0/549
composite	20/120	0	0	0	0	0	0/549

Two readings. The population marginal detects **76 of 120 account-takeover events, 63% recall**, and that is the only planted type any arm reaches — **five of six are invisible to everything**, including low-and-slow, which the design's dispersion widening was expected to miss. And the two useful arms are sensitive to *disjoint* things: the marginal to planted takeover, the novelty detector to the real campaign.

3.4 A budget is a ceiling, not a quota

With a few hundred labelled events in the corpus, most of what a large budget permits is cost without return. Truncating each queue where U peaks ($v/c = 10$, lanl-r11):

BUDGET	PERMITTED	TP	OPTIMAL	TP	PRECISION	SUPPRESSED	TP FORGONE
10/day	70	4	30	4	6.7% → 13.3%	40	0
100/day	700	47	221	47	6.7% → 21.3%	479	0

At a 100/day budget, **68% of the queue can be suppressed for zero lost detections** and precision triples. For the composite, whose queue holds no true positives at all, the optimum is to emit nothing — the objective correctly declining to deploy it.

This is an oracle bound: the optimum is located using the labels, so it measures the headroom a cutoff has rather than being a deployable rule. A deployable version needs a per-alert probability of being a true positive.

3.5 Budgets of 10, 100 and 1000 per day, and Detector V

Left blank: the runs are in progress. No recorded run yet includes Detector V, so nothing in this paper claims it works.

3.6 What the baselines do

Six population-scope baselines spanning four inductive biases — isolation forest, extended isolation forest, half-space trees, local outlier factor, one-class SVM, PCA — detect **0 of 262** at every budget on the matched comparison. One per-entity baseline, an uncalibrated EWMA z-score, detects **1**. Isolation, density, boundary and linear-subspace models fail together, and the category census says why: not one labelled event is a population-marginal outlier.

The framework's novelty arm catches 21 where that per-entity baseline catches 1. The direction of the comparison — per-entity beats population — is the finding the evidence supports; the margin over the baseline rests on a single event and could reverse on another campaign.

4. Threats to validity

Stated because a result that does not name its own weaknesses is not a result.

1. **One corpus, one campaign.** Every quantitative claim rests on LANL authentication and a single red-team campaign whose characteristics are not known to be representative.
2. **Entity sampling inflates measured rates.** Labelled entities are exempt from every sample, so a subset carries a fraction of the background against all of the labelled population. Sampled rates are **not** comparable to full-population ones.
3. **The per-arm detectors have never been measured on the full corpus.** The only full-population run records the composite alone, at 0. Whether the novelty detector's 60 survives at a base rate ten times lower is **unmeasured**, and it is the most important outstanding experiment.
4. **The per-entity baseline margin is thin**, resting on one event.
5. **Entity-day results are confounded by activity**, and the confound accounts for most of the effect: pricing in the event count takes 25 of 46 down to 2.
6. **The open-vocabulary estimator is untested on an open vocabulary.**
7. **No committed result was produced through the persistent store.** Every recorded run used in-memory state; the database path exists and is exercised only by tests.

5. Conclusion

The evidence points in one direction, and it is not the direction the design anticipated.

Per-entity conditioning works and population-scope conditioning does not. On this corpus the per-entity novelty detector finds labelled red-team activity at every budget tested, replicated across disjoint entity samples, while six published population-scope models and the framework's own population arms find none. The

mechanism is visible in the category census: the labelled events are not population outliers, so no amount of technique applied at population scope reaches them.

Stop combining. One detector carries the signal, and combining it with four uninformative ones costs accuracy under every rule tried. Presenting each signal on its own terms is also more actionable: "this account used a program it has never used" is an instruction, and a blended score is not.

Move the unit of analysis to where the design already put it. The framework argues that the entity is the unit; the evaluation ranked events. Closing that gap produced the only non-zero composite detection, and the remaining work is to remove the activity confound rather than to discover the effect.

Make precision the control. Alert volume is now explicitly unbounded and the objective is expected utility, so an unbounded queue that is mostly right is preferred to a bounded queue that is mostly wrong. Measured on a real run, the utility-optimal cutoff discards two thirds of a queue at no cost in detections — the headroom for a deployable cutoff rule is large, and building one needs a calibrated per-alert probability.

What is not claimed: that this detects insider threat at deployable precision. Sixteen per cent of a queue being real is a thousand-fold improvement on chance and still not good enough to alert on unattended, and five of six synthetic attack types are invisible to every arm tested. What is established is narrower and more useful — that the per-entity formulation carries signal where the population formulation carries none, and that the combination layer is the defect standing between the two.

References

1. Axelsson, S. *The base-rate fallacy and its implications for the difficulty of intrusion detection*. ACM CCS, 1999.
2. Kent, A. D. *Comprehensive, Multi-Source Cyber-Security Events*. Los Alamos National Laboratory, 2015. CCo 1.0.
3. Brown, M. B. *A method for combining non-independent, one-sided tests of significance*. Biometrics 31(4), 1975.
4. Fisher, R. A. *Statistical Methods for Research Workers*. Oliver and Boyd, 1932.
5. Karrer, B. and Newman, M. E. J. *Stochastic blockmodels and community structure in networks*. Physical Review E 83, 2011.
6. Good, I. J. *The population frequencies of species and the estimation of population parameters*. Biometrika 40, 1953.
7. Šidák, Z. *Rectangular confidence regions for the means of multivariate normal distributions*. JASA 62, 1967.
8. Benjamini, Y. and Hochberg, Y. *Controlling the false discovery rate*. JRSS B 57(1), 1995.

Generated by `cmd/thesis` from `docs/THESIS.md`, which stays canonical for the prose: this page is never edited directly, so the two cannot disagree. Every quantitative claim traces to a recorded run in `results/`. Diagrams are hand-authored inline SVG with no external resources, and their two carrying colours are validated for contrast and colour-vision separation against both the light and dark surfaces.